



IPB University  
— Bogor Indonesia —

JATI BAHAGYA

# Perancangan Keamanan Informasi - E-Commerce JatiBahagya



Project Keamanan Informasi

Kelompok 6 - K2

- Taura Mohamad Inzaghi ( G6401231019 )
- Muhammad Fauzan Akbar ( G6401231045 )
- Muhammad Syafiq Romadhon ( G6401231079 )

**Dosen pengampu:** Shelve Nidya Neyman







# OUR TEAM



**Muhammad Syafiq Romadhon**  
**( G6401231079 )**



**Muhammad Fauzan Akbar**  
**( G6401231045 )**



**Taura Mohamad Inzaghi**  
**( G6401231019 )**

# Apa Itu Jatibahagya dan Mengapa Keamanannya Penting?

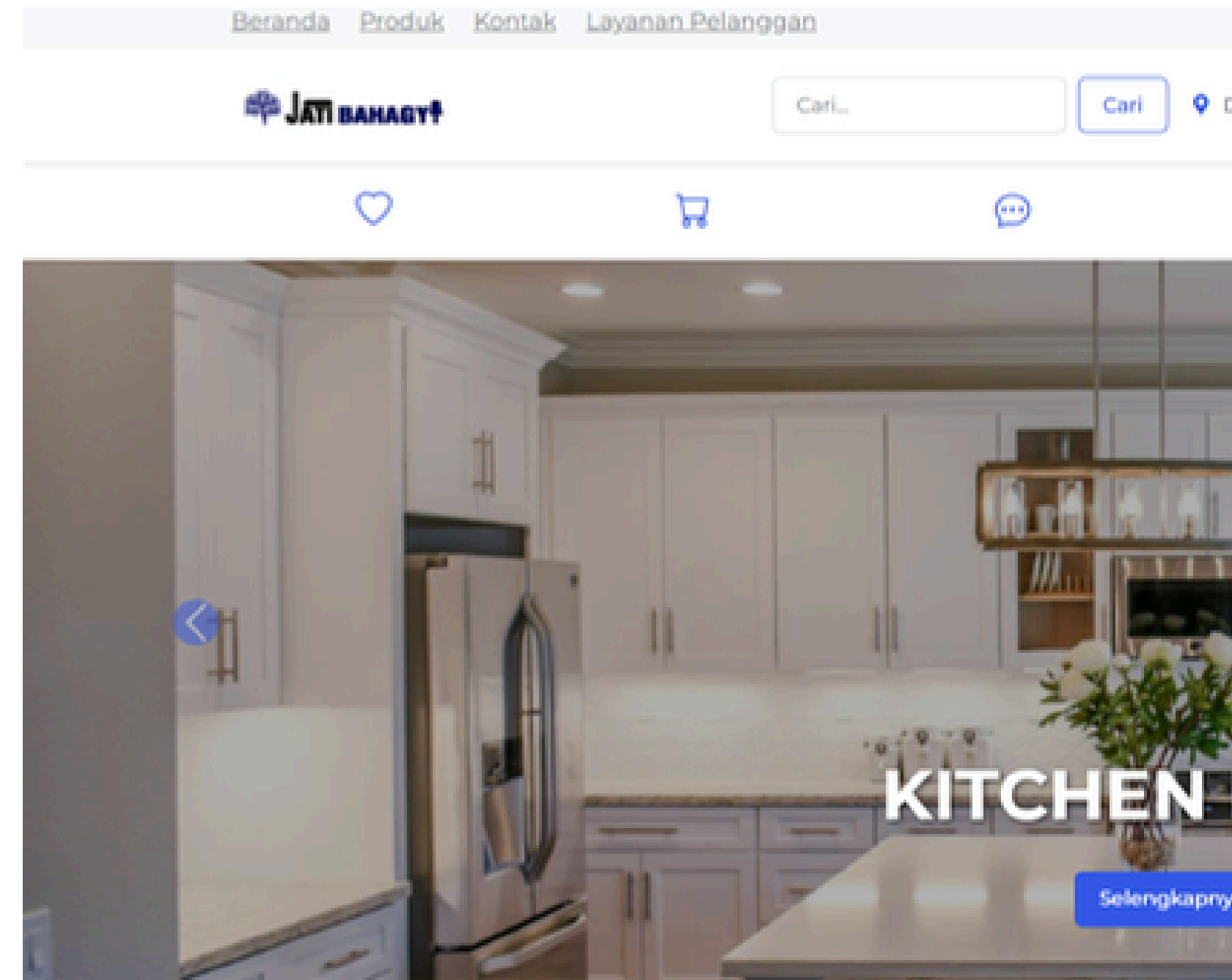
E-Commerce Jatibahagya merupakan platform e-commerce furnitur yang mengintegrasikan katalog produk, manajemen inventaris, dan fitur komunikasi pelanggan.

## Masalah Keamanan yang Ingin Diselesaikan:

- Kerentanan Kredensial Pengguna (password, kontak, alamat)
- Akses Data Tidak Sah (ancaman peretasan)

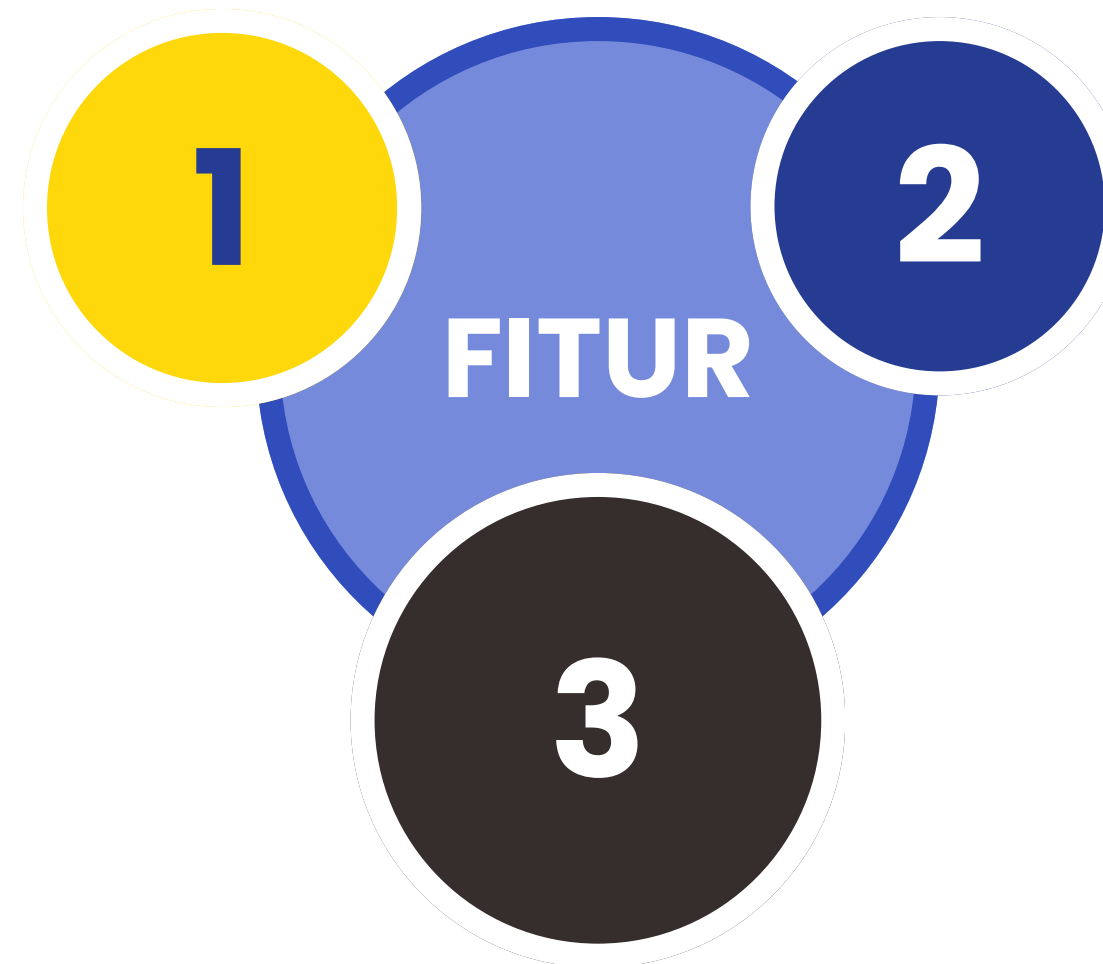
## Risiko Jika Tidak Ada Mekanisme Keamanan (Tanpa Enkripsi):

- Kebocoran Data Pelanggan (Data Breach)
- Penyadapan dan Penipuan (Man-in-the-Middle Attack)
- Manipulasi Sistem Administrasi (mengubah harga, mengacaukan stok kayu jati, atau memanipulasi pesanan)
- Kehancuran Reputasi Bisnis (menghancurkan kepercayaan pelanggan)



# Fitur Utama

Autentikasi dan manajemen akun:  
Sistem mendukung registrasi, login,  
reset password, verifikasi OTP, serta  
pengelolaan profil dan alamat  
pengiriman pengguna.

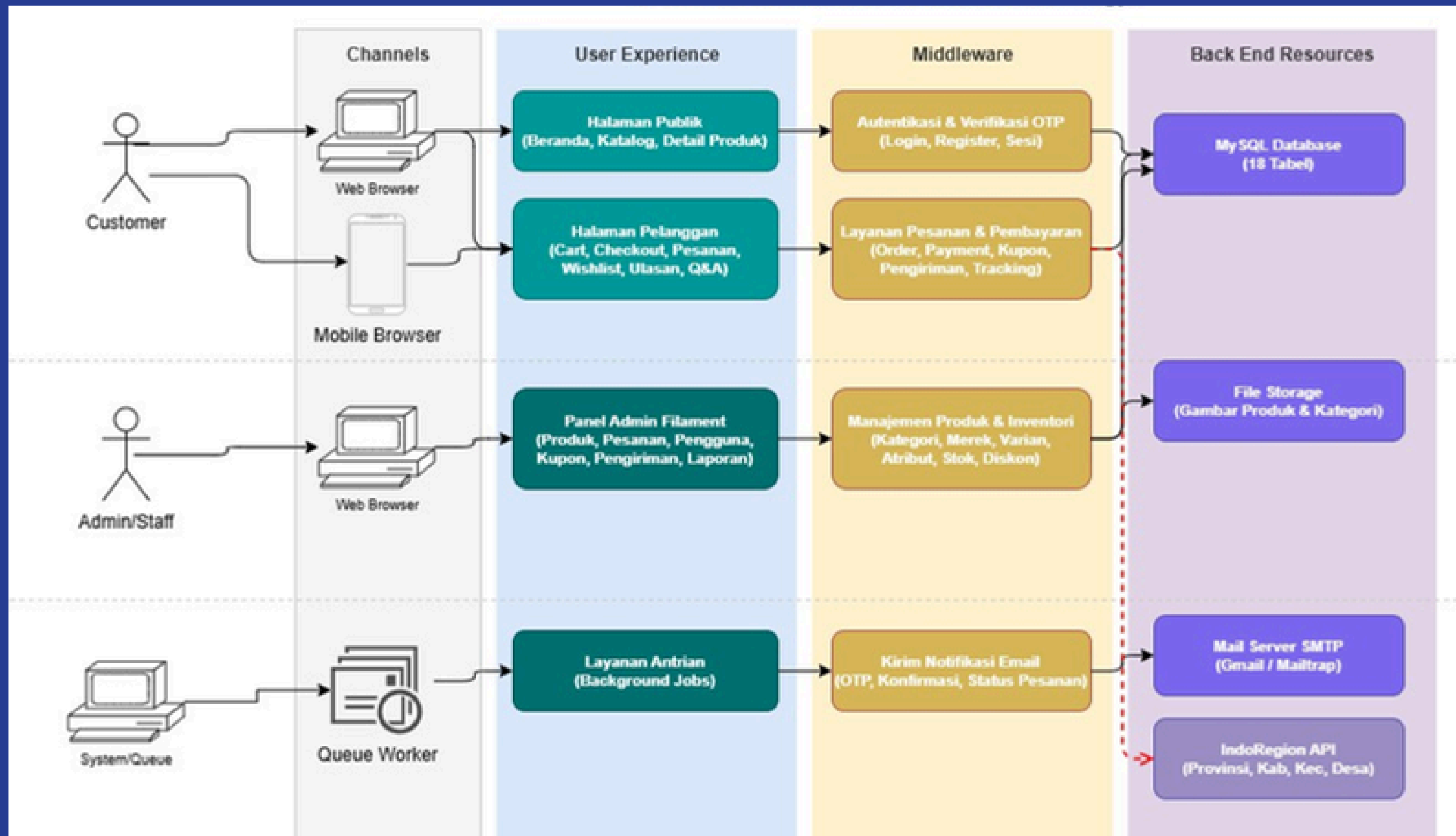


Katalog dan pencarian produk:  
Pengguna bisa melihat daftar  
produk, membuka detail produk,  
memfilter berdasarkan kategori  
atau brand, melakukan pencarian,  
dan menyortir produk.

Keranjang belanja dan checkout:  
Pengguna bisa menambah produk ke keranjang,  
mengubah jumlah item, menghapus item, lalu  
melakukan checkout untuk membuat pesanan.



# ARCHITECTURE DIAGRAM



# Threat Modeling: Analisis Risiko Keamanan Jatibahagya

## Aset yang dilindungi:

- Data Kredensial & Autentikasi
- Data Sistem & Database
- Akun dan Hak Akses

## Ancaman Utama

- Brute-force Attack
- SQL Injection
- Session Hijacking
- Cross-Site Scripting (XSS)



### Brute-Force Attack

Sasaran/celah:

- login

Dampak:

- akses tidak sah

Mitigasi:

- enkripsi password
- rate limiting
- CAPTCHA
- HTTPS



### SQL Injection

Sasaran/celah:

- login
- pencarian produk

Dampak:

- akses data sensitif
- ubah & hapus database

Mitigasi:

- prepared statement
- parameter binding
- validasi & sanitasi input
- akses least privilege



### Session Hijacking

Sasaran/celah:

- Session ID

Dampak:

- akses tidak sah
- salah guna fitur
- ubah & hapus data

Mitigasi:

- koneksi HTTPS
- session ID acak
- cookie HTTPOnly



### Cross-Site Scripting (XSS)

Sasaran/celah:

- form input (pencarian produk)

Dampak:

- curi cookie atau session
- alih ke situs bahaya
- jalan script bahaya

Mitigasi:

- validasi & sanitasi input
- escaping karakter HTML
- Content Security Policy (CSP)
- Hindari fungsi eksekusi kode input pengguna



# Apa Saja Sih Kebutuhan Keamanan?

|                        |                                                                    |                       |                                                                            |
|------------------------|--------------------------------------------------------------------|-----------------------|----------------------------------------------------------------------------|
| <b>Confidentiality</b> | Hanya pihak berwenang yang dapat melihat data (Enkripsi).          | <b>Authentication</b> | Verifikasi identitas pengguna secara akurat (Login aman).                  |
| <b>Integrity</b>       | Data bebas dari manipulasi atau perubahan ilegal (Sanitasi input). | <b>Authorization</b>  | Pembatasan hak akses sesuai peran (Least Privilege).                       |
| <b>Availability</b>    | Sistem andal dan selalu siap diakses pengguna sah.                 | <b>Accountability</b> | Perekaman jejak aktivitas sistem untuk pertanggungjawaban (Audit Logging). |

# Bagaimana Sistem Mengatasi Ancaman yang Telah Diidentifikasi?



## Data at Rest

- Penyimpanan Password dengan Bcrypt
- Penyimpanan OTP yang Bersifat Sementara
- Integritas Struktur Data dari Injeksi



## Data in Transit

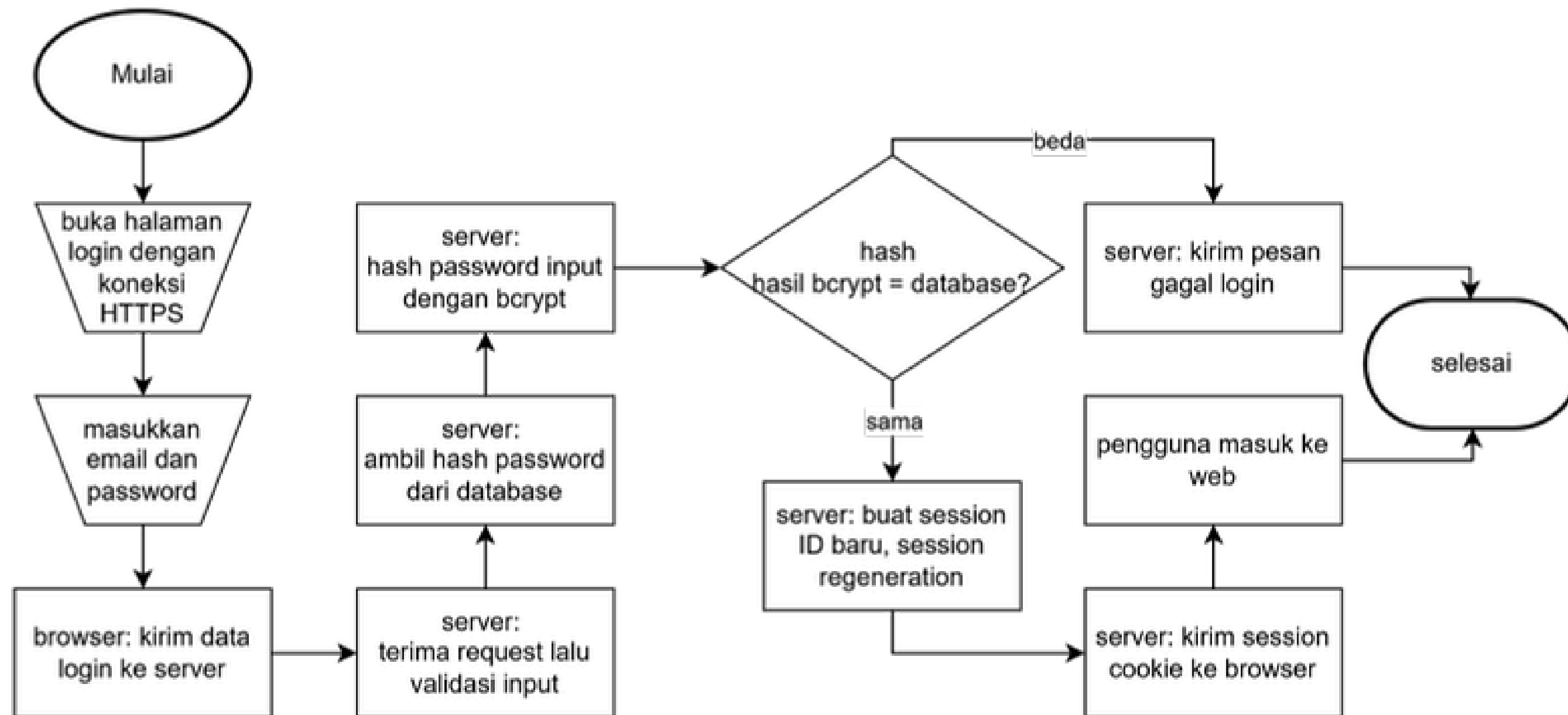
- Koneksi Terenkripsi dengan HTTPS
- Transmisi Session Cookie yang Aman
- Pengiriman OTP melalui Jalur Terpisah



## Key Management

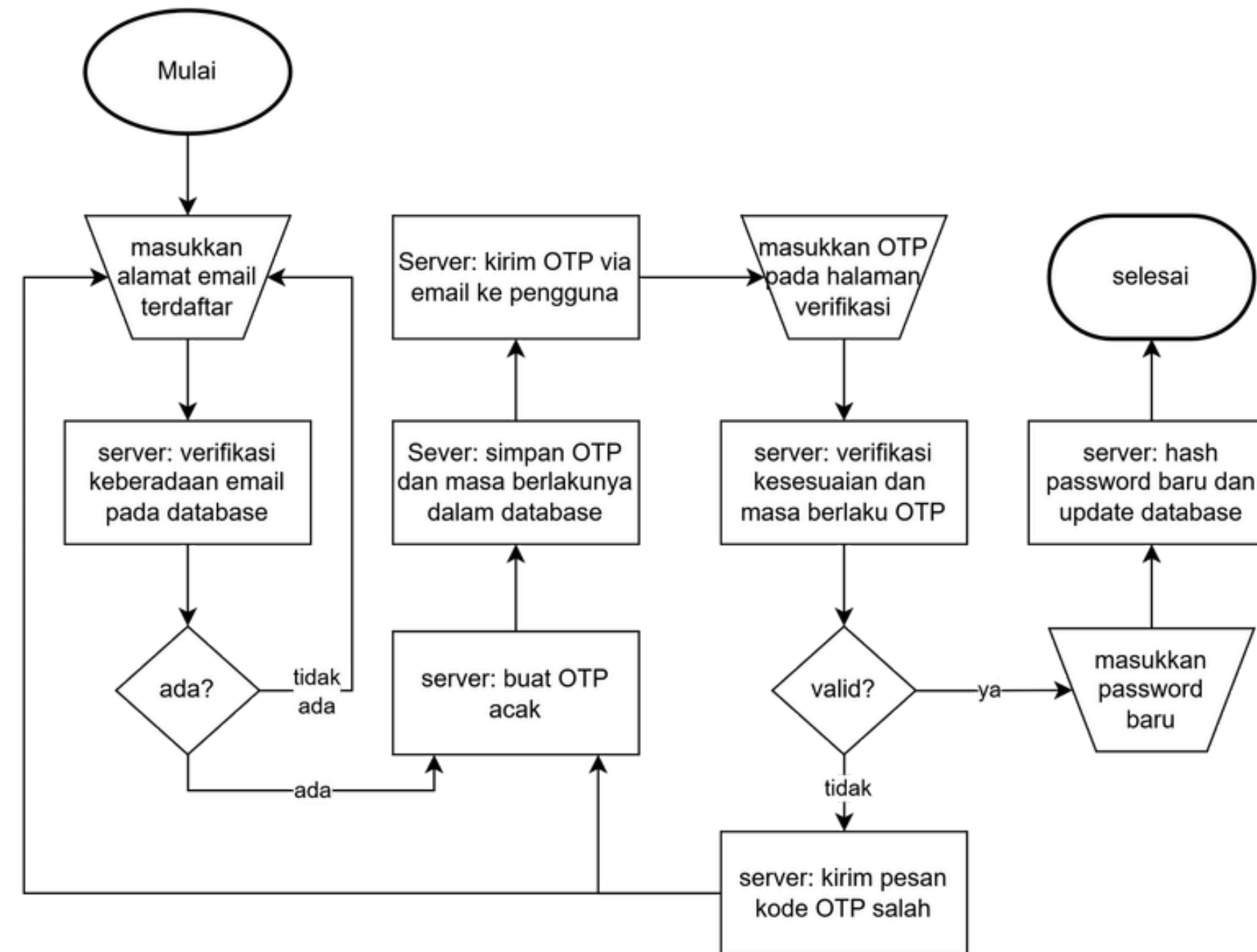
- Session Regeneration (Rotasi Session ID)
- Otomatisasi Salting pada Bcrypt
- Pembangkitan OTP Acak (Randomness)

# DESAIN MEKANISME KEAMANAN : Protokol Autentikasi pengguna

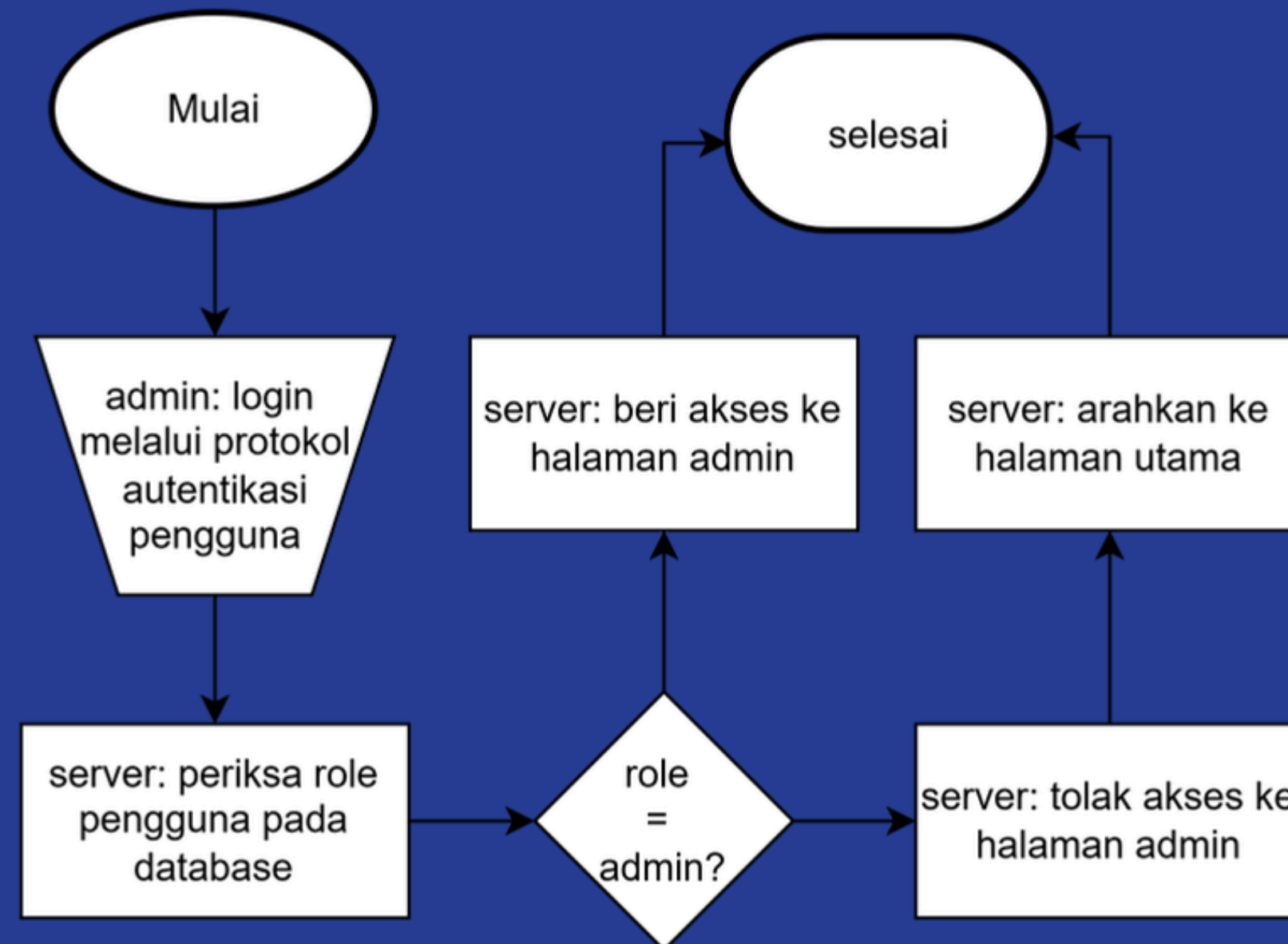




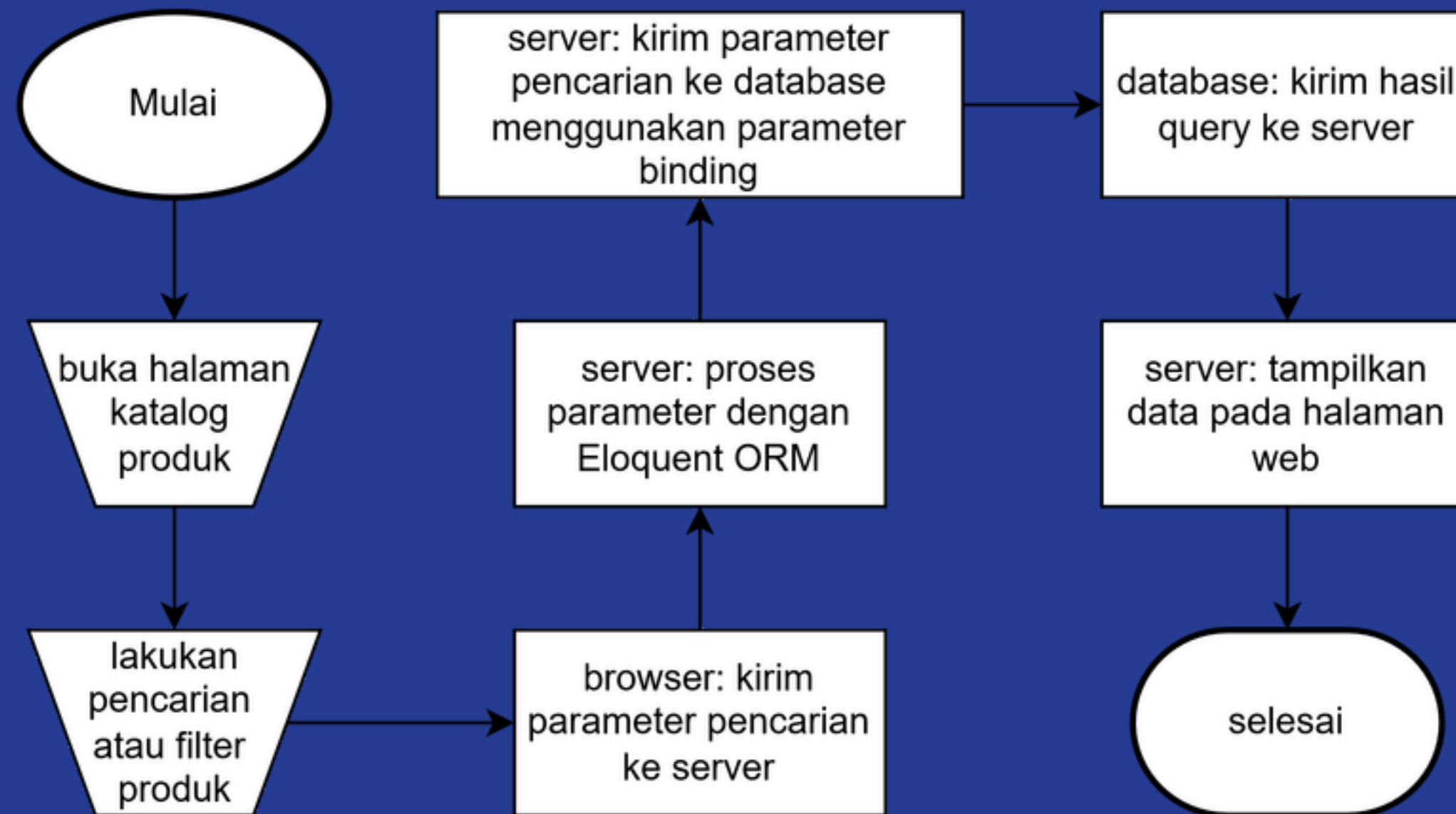
# DESAIN MEKANISME KEAMANAN : Protokol Reset Password dan OTP



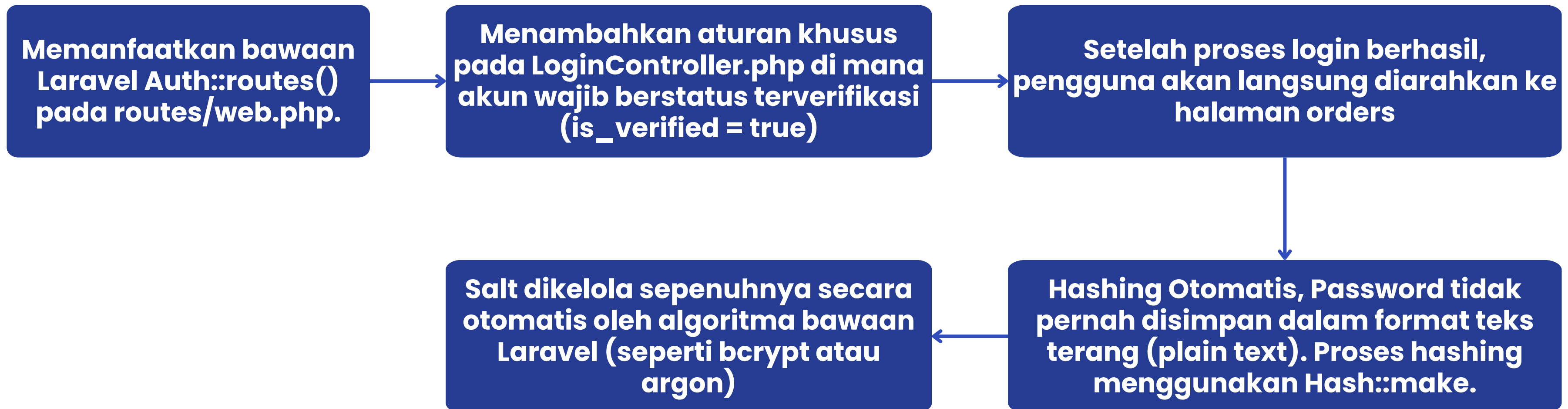
# DESAIN MEKANISME KEAMANAN : Protokol Akses Modul Admin



# DESAIN MEKANISME KEAMANAN : Protokol Pengambilan Data Produk



# Implementasi Authentication





# Implementasi Authorization

## Otorisasi Sisi Pengguna Biasa

- Halaman fitur utama (seperti cart, order, profil, wishlist, alamat, dan review) dikunci menggunakan middleware auth di routes/web.php (hanya untuk pengguna yang sudah login)
- Middleware CheckVerified.php memblokir pengguna yang status `is_verified`-nya masih false. Pengguna tersebut akan otomatis di-logout dan dialihkan ke halaman verifikasi.

## Otorisasi Sisi Administrator

- Area admin dipisahkan secara rapi melalui panel Filament (AdminPanelProvider.php) pada path `/admin`, yang dilindungi oleh middleware autentikasi khusus bawaan Filament.

# Implementasi Accounting

Log created\_at dan update\_at:

- Pencatatan kapan dibuat dan diubah pada attribute seperti order, akun.

| 🕒 created_at ▼      | 🕒 updated_at ▼      | A-Z otp ▼ | 🕒 otp_expires_at ▼  |
|---------------------|---------------------|-----------|---------------------|
| 2026-03-12 17:08:11 | 2026-03-12 17:08:49 | 430986    | 2026-03-12 17:38:49 |
| 2026-03-12 17:09:56 | 2026-03-12 17:10:54 | 592368    | 2026-03-12 17:40:54 |
| 2026-03-13 01:12:58 | 2026-03-13 01:17:18 | [NULL]    | [NULL]              |
| 2026-06-02 07:42:55 | 2026-06-02 07:43:34 | [NULL]    | [NULL]              |
|                     |                     |           |                     |

# Implementasi Kriptografi

- Fungsi Hash::make() pada kontroler registrasi dan didukung oleh cast hashed pada model User.php
- Salt ditangani sepenuhnya secara otomatis oleh algoritma hashing bawaan framework Laravel
- Konfigurasi pada config/app.php menunjukkan bahwa aplikasi telah menyiapkan fondasi kriptografi menggunakan algoritma AES-256-CBC yang diamankan oleh APP\_KEY.

| A-Z email           | A-Z password                                 |
|---------------------|----------------------------------------------|
| fauzan@email.com    | \$2y\$12\$0slXLeoZbVFKTUfVySDwAOuaHoCZHIjT6  |
| akbar3776@gmail.com | \$2y\$12\$T5ozqe3v3mpQ3msx/KSeFO28HlKmqWc    |
| akbar@email.com     | \$2y\$12\$pcBWJDxwgdW5slL7J4B1jOUpF2JqT.jm9j |
| andra@gmail.com     | \$2y\$12\$eNzpRXRhRzY7VGnWoc93L.CiXt5V37VPI  |

# Hasil Pengujian

- test\_verified\_user\_can\_login\_and\_redirects\_to\_orders: apakah pengguna yang sudah diverifikasi dapat berhasil login dan diarahkan ke halaman yang benar
- test\_unverified\_user\_cannot\_login: aturan sistem yang menolak login bagi pengguna yang belum diverifikasi, meskipun email dan password-nya benar
- test\_authenticated\_user\_can\_logout: apakah pengguna yang saat ini sedang login dapat melakukan logout dengan benar dan sesinya dihancurkan

```
Runtime:      PHP 8.4.18
Configuration: D:\Games\Code\Semester 6\wavemoon-be-060525-2\wavemoon-be\03_Sour
...
3 / 3 (100%)

Time: 00:00.981, Memory: 60.00 MB

OK (3 tests, 11 assertions)
```

# Analisis Kinerja

## Sebelum Penerapan

Karena pada pengembangan telah diterapkan keamanan (enkripsi & verifikasi), perkiraannya jika sebelum diterapkan adalah:

- Response Time: Sangat cepat
- Latency: Rendah
- Ukuran Data: Lebih kecil
- CPU & RAM: Rendah

## Sesudah Penerapan

Setelah diterapkan keamanan (Bcrypt, HTTPS, OTP, Middleware):

- Response Time: Lebih Lambat (eksekusi hash dan pencocokan Bcrypt)
- Latency: Sedikit meningkat (proses TLS/SSL Handshake untuk tukar kunci)
- Ukuran Data: Sedikit lebih besar (hash Bcrypt 60 karakter tetap)
- CPU & RAM: Meningkat (Algoritma hashing Bcrypt intensif ke CPU dan proses enkripsi/dekripsi)



# Kesimpulan

## Keterbatasan sistem

- Kode OTP masih disimpan di dalam database dalam bentuk teks terang (plaintext)
- OTP saat ini hanya berfungsi untuk verifikasi pendaftaran akun baru, bukan sebagai pengaman ganda saat pengguna masuk ke dalam sistem

## Pengembangan Berikutnya

- Penerapan Kriptografi pada OTP
- Integrasi 2FA/MFA

# Terima Kasih